Assignment 1: Buffer Overflow Attack

Secure Systems Engineering (CS6570)
Indian Institute of Technology Madras

Files Provided & How to Run

You have been given the following files as part of the assignment:

- `Commands.md`
- `gef.py`
- `nocanary.c`
- `payloadCreate1`
- `start.bat`
- `withcanary`
- `Dockerfile`
- `nocanary`
- `payload_1`
- `start.sh`

To run the binary `nocanary` on a UNIX-like host:

```
chmod +x start.sh
sudo ./start.sh
```

Inside the Docker container:

```
# Normal execution
./nocanary "<some_string>"

# Exploit using the provided payload file
./nocanary $(cat payload_1)
```

Download

Each folder is named with the student's roll number and contains the set of binaries and supporting files assigned to that student. Download the folder that matches your roll number from **here** and use the files within.

Important: Do not copy payloads, reports, or binaries from other students. Each binary is slightly different, and copying will likely fail.

Problem Description

You are provided with two binaries:

- `withoutcanary`
- `withcanary`

Both binaries contain a buffer overflow vulnerability. One we have demonstrated in class and given the payload as well. The other binary, i.e. `withcanary`, is protected by an additional **self-implemented stack canary mechanism**.

Analyze the `withcanary` binary and:

- Study the canary implementation used in the binary.
- Devise a method to bypass the canary protection.
- Construct a payload that successfully exploits the buffer overflow vulnerability.
- Execute the `exploit` function without triggering the canary detection.

Execution and Evaluation

The payloads will be evaluated using an automated script that executes the binary as follows:

```
./withcanary $(cat payload_2)
```

Important:

- The execution must result in a **clean exit**.
- Any segmentation fault or abnormal termination will result in a deduction of marks.

Submission Requirements

You must submit the following:

1. Payload files/scripts used for exploitation.
2. A detailed report describing:
    - Your approach to analyzing the binaries.
    - The methodology used to generate the payloads.
    - How the canary protection was bypassed.
    - Challenges faced and how they were resolved.
3. Screenshots of terminal output showing:
    - Successful execution of the exploit.
    - Clean program termination.

Resources

You may refer to the following resources:

- Lecture slides and tutorial examples
- `commands.md` file provided with the assignment
- Official documentation and manuals (e.g., `gdb`, `objdump`, `readelf`)

Note: All external resources used must be clearly mentioned in your report.

Academic Integrity

This assignment is to be completed individually. Any form of plagiarism or sharing of payloads or reports will be treated as a violation of academic integrity policies.

Marks Distribution

- Exploitation without canary: 50 marks
- Clean exit: 20 marks
- Report quality and explanation: 30 marks